

Confidentiality is Key to Awareness

資 安 保 密 守 護 智 財

A D C x I T 資 安 專 家 對 談

辦 公 室 資 安 實 務 / 工 具 風 險 / 法 律 紅 線

2 0 2 5 / 0 7 / 2 2

議程說明

- 辦公室存在隱形陷阱 / 20 min
- 方便與風險之間的拔河 / 30 min
- 若跨越過紅的線 的代價 / 30 min
- 給設計師的通則建議 / 20 min

P a r t 1

辦 公 室 存 在 隱 形 陷 阱

善 意 行 為 可 能 帶 來 資 安 漏 洞 ？

Q 1 - 1

在很多公司的資安宣導中，都會提到一些看似「出於善意」卻可能帶來風險的行為，例如隨手幫助同事處理事務，或是無意間接觸到非自己業務範圍的資訊。能否請專家從專業角度分析，這類行為在真實世界中，可能會如何演變成一個資安漏洞？

學到甚麼？

對非直接負責的專案做到不主動窺視與探索的行為

非禮勿視、非禮勿聽、非禮勿言

Q 1 - 1 善意行為可能帶來資安漏洞?

重點note

即使是出於善意，例如隨手幫助同事處理非自己業務範圍的事務，或無意間接觸到敏感資訊，都可能導致資安風險。實務案例顯示，即使是個人文件若未妥善保存（如隨意丟棄被回收人員撿走），也可能造成資料外洩。公司資料有明確分級（四級），不屬於自己權限的資料不應接觸。紙本資料應透過碎紙機手動銷毀，或參與每月集中銷毀流程（由外部水銷公司處理，並有特殊藥水銷毀）。若不慎影印多餘的敏感資料，應立即銷毀。若看到不該看的資料，在良善角度下，可通知相關人員處理。

學到甚麼？

- 作為設計師，應嚴格遵守資料分級制度，不主動探究非職責範圍的資訊。
- 對於實體文件，務必確保妥善保管與銷毀，避免因疏忽造成資安漏洞。
- 對非直接負責的專案做到不主動窺視與探索的行為。非禮勿視、非禮勿聽、非禮勿言

P a r t 1

辦公室存在隱形陷阱

隨手鎖定電腦的重要性

Q 1 - 2

在內部網路威脅的實務經驗中，「未鎖定電腦」最常導致哪些類型的資安事件？例如帳號被盜用、資料被外洩、或惡意程式被植入？可否分享一兩個實際的攻擊情境？

學到甚麼？

一離開座位就需將個人電腦做登出的動作

不可以私自請同仁在本人沒有在場的時候協助操作電腦

Q 1 - 2 隨手鎖定電腦的重要性

重點note

電腦鎖定是防止內部網路威脅的關鍵措施。公司已強制執行 15 分鐘自動鎖定螢幕的政策，符合 ISO27001 要求。然而，即使有自動鎖定，個人也應養成離開座位立即手動鎖定電腦的習慣。曾有真實案例顯示，公司高層在咖啡廳工作，僅離開片刻去拿咖啡，未鎖定的簡報內容就被他人看到。此外，絕不可在本人不在場時，私自請同事協助操作電腦。

學到甚麼？

- 養成隨手鎖定電腦的習慣是保護設計資料的第一道防線。
- 即使是短暫離開，也應確保電腦處於鎖定狀態。
- 避免**本人不在現場時**將個人電腦交由他人操作。若有**特殊工作需求時**須要經**主管同意** (teams/email文字記載)後有第三人陪同時操作，並於返回工作崗位後立即更改OA密碼。

P a r t 1

辦公室存在隱形陷阱

實體產出資料的資安盲點

Q 1 - 3

對於高度依賴實體產出（如設計圖、模型、會議筆記）的團隊來說，在處理這些資料時最常見的資安盲點是什麼？能否分享一些關於「實體機密資料生命週期管理（從產出、儲存到銷毀）」的一些經驗？

學到甚麼？

需確認專案相關之實體材料被妥善且具隱密性保管

專案開發週期結束或產品EOL後得以將專案相關之實體材料依規定銷毀或回收

Q 1 - 3 實體產出資料的資安盲點

重點note

對於設計團隊高度依賴的實體產出（如設計圖、模型、會議筆記），其資安盲點在於生命週期管理缺乏統一的法律法規，主要依賴各部門自行規定(按照ADC規範)。資料應在**失去效果或達到收集目的**後銷毀。銷毀方式需確保資料**不可辨識**，包含機敏資訊的紙類資料應統一由公司水銷處理。

- *ADC應定義自己的產出物生命週期 (待定)

學到甚麼？

- 設計師應了解並遵守部門內關於實體設計產出的生命週期管理規定，確保從產出、儲存到銷毀的每個環節都符合資安要求，特別是銷毀時需達到不可辨識的程度。
- 需確認專案相關之實體材料被妥善且具隱密性保管
- 專案開發週期結束或產品EOL後得以將專案相關之實體材料依規定銷毀或回收

P a r t 1

辦公室存在隱形陷阱

拍白板記錄會不會有資安風險？

Q 1 - 4

許多團隊會用手機拍攝白板或會議紀錄。從資安角度來看，建議的標準作業流程(SOP)應該包含哪些步驟，才能確保這些暫存在個人裝置上的資訊，不會成為新的風險點？

學到甚麼？

拍完照片要從手機裡刪除

只能拍自己專案的資訊

Q 1 - 4 會議白板記錄相關資安風險

重點note

許多團隊會使用手機拍攝白板或會議記錄。從資安角度看，這類行為存在風險，因為暫存於個人裝置上的資訊可能成為新的風險點。目前公司對於個人設備 (BYOD) 的相關規定尚不明確，也未造成重大損失。

學到甚麼？

- 設計師應避免使用個人手機拍攝包含機密設計內容的白板或會議記錄。
- 若必須拍攝，應僅限於與自己專案相關的非機密資訊，並在完成後立即從手機中刪除。
- *ADC需明確定義日常工作可以用手機拍照的情境並由主管公開說明(待定)

P a r t 2

方 便 與 風 險 的 拔 河

把資料丟進 AI 工具風險有多大？

Q 2 - 1

員工使用個人帳號將工作資訊上傳到公開雲端或生成式AI平台，資料的控制權和所有權會有什麼變化？背後最大的技術與法律風險是什麼？

學到甚麼？

Q 2 - 1 使用 AI 工具風險與建議

重點note

員工使用個人帳號將工作資訊上傳到公開雲端或生成式 AI 平台，會導致資料控制權和所有權的變化。最大的技術與法律風險在於資料可能被用於模型訓練，或被第三方存取。公司設有 GENAI 委員會，提供**認證清單**，建議使用清單上的平台。若需使用清單外的平台，應向委員會提出申請。在使用任何 AI 工具前，務必對敏感資料**進行去識別化處理**。

學到甚麼？

- 設計師在使用 AI 工具時，應優先選擇公司**認證的平台(*附上連結)**。
- 須透過公司的AI hub來使用GPT 4o等模型，工作相關內容避免直接使用ChatGPT網頁版。
- 使用AI始終對敏感設計資料進行**去識別化處理**，以避免智慧財產權和資料洩露風險。

P a r t 2

方 便 與 風 險 的 拔 河

附 件 v s . 共 用 連 結

Q 2 - 2

檔案分享時，我們建議推薦使用「共用連結」而非「傳送附件」是對的嗎？
能否解釋兩種方式的安全性差異？若是敏感檔案，共用時應該注意哪些權限設定？

學到甚麼？

Q 2 - 2 附件 VS. 共用連結

重點note

使用「共用連結」是管控文件權限的最佳方式，因為離職後可立即停用連結。建議透過teams的管理者，進行權限管理和溝通。寄信建議用**公司組織群組代號**Group Address (如!20-ASUS-SYS_BG-CS_BU-Design_Ctr(設計中心) / #ADC_TPE_B1&15F“ <#ADC_TPE_B1&15F@intra.asus.com)來設定。

學到甚麼？

- 設計師在分享設計文件時，應優先使用teams的共用連結功能，並確保設定正確的權限，而非直接傳送附件，以利於資安管控。
- 控管連結的權限優先依照**公司組織群組代號/teams頻道**來設定權限。

P a r t 2

方 便 與 風 險 的 拔 河

密 碼 與 浮 水 印 相 關

Q 2 - 3

對敏感文件（如PDF）加密時，密碼與檔案需分開傳遞有沒有最佳渠道？有無利弊風險？
對於「浮水印」的資安需求，有沒有推薦的工具或自動化流程？

學到甚麼？

檔案外傳須加上相對應的浮水印作控管與追蹤

容量過大的檔案外傳也可以透過壓縮檔(ZIP)設定密碼來增加保護性

Q 2 - 3 密碼與浮水印相關

重點note

對於敏感文件 (如 PDF) 加密時，密碼與檔案應分開傳遞。資安單位正在研究使用微軟提供的標籤作為浮水印，實現整頁浮水印 (Trust View)，以加強資料控管和追蹤。雖然這可能增加操作的麻煩，但對於檔案外傳的控管和追溯至關重要。對於容量過大的檔案，可透過壓縮檔 (ZIP) 設定密碼來增加保護性。

- 可請教文管，永續單位的am王
- 定義ADC制式template (內容/位置) ← 由ISD現有內容當示範開始依需求調整
- ADC定義使用等級、情境
- 人工上?小工具?現有pdf軟體功能

學到甚麼?

- 對於外傳的檔案文件，務必加上**浮水印**以利控管追蹤。
- 密碼跟檔案連結不要用同一個方式傳送，或至少要分成兩封email傳送。
- 容量過大的檔案外傳也可以透過壓縮檔(ZIP)設定密碼來增加保護性

P a r t 2

方 便 與 風 險 的 拔 河

跨 團 隊 資 訊 共 享 流 程 該 怎 麼 注 意 ？

Q 2 - 4

包含BU內部跨團隊、跨BU、甚至對外(ODM、供應商)
在不違反資安規範前提下，什麼才是標準合規的資訊共享流程？
員工要如何判斷自己行為沒有違反資安規範？

學到甚麼？

Q 2 - 4 跨團隊資訊共享流程該怎麼注意？

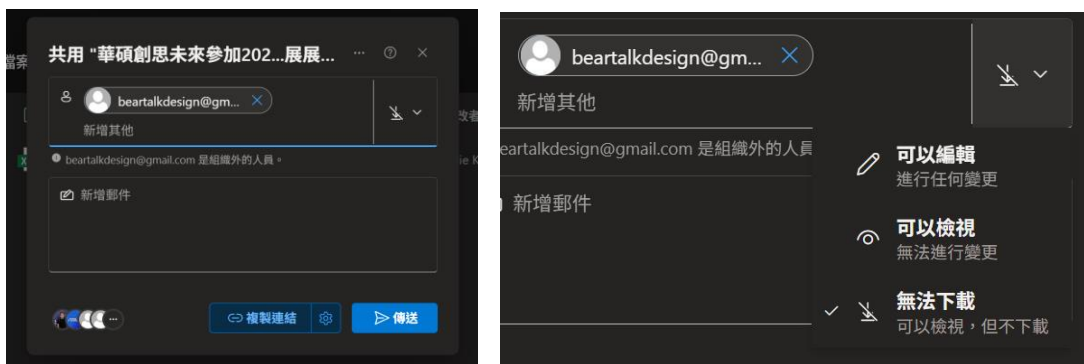
重點note

跨團隊資訊共享（包括 BU 內部、跨 BU 甚至對外與 ODM/供應商）需在不違反資安規範的前提下進行。標準合規的流程應包含資料分級、權限控管，並在必要時進行去識別化。員工應了解如何判斷自己的行為是否違反資安規範。

- One Drive連結外部權限控管

學到甚麼？

- 從資安角度，寄給外部廠商時以email寄送One Drive連結為佳，避免直接夾帶附件可降低風險。
- 設計師在進行跨團隊協作和資訊共享時，應主動了解並遵循公司的資安規範，確保共享的設計資料符合分級要求，並僅授予必要的存取權限。



P a r t 2

方 便 與 風 險 的 拔 河

網 路 連 線 W i - F i / V P N 相 關 風 險

Q 2 - 5

出差在外面或在家工作時，常會公開(如飯店)的 Wi-Fi，就算會開 VPN，就能安心了嗎？請問從資安角度來看，像這樣的行為有哪些風險？
若有遠端會議需討論，建議如何應對？
有沒有什麼「最安全的做法原則」可以帮大家降低連網時的風險？

學到甚麼？

Q 2 - 5 網路連線 Wi-Fi / VPN 相關風險

重點note

員工普遍因工作便利性而忽略VPN的持續連線，僅在打卡等行政事務時使用。在外部（如飯店、咖啡廳）工作時，常使用安全性較低的公共Wi-Fi，這可能帶來資安風險。應加強宣導，建立員工「不是能用就好」的正確網路安全觀念。

學到甚麼？

- 設計師在外部或居家辦公時，應警惕公共 Wi-Fi 的風險，使用OA要先連上VPN 才進行上網行為。
- 應優先使用公司提供的安全網路連線方式，並避免在不安全的環境下處理敏感設計資料。

P a r t 2

方 便 與 風 險 的 拔 河

外 出 與 居 家 工 作 相 關 風 險

Q 2 - 6

居家工作時，會需要攜帶對應工作參考用的實體設備與材料，例如筆電、圖板、模型、樣品等等。。。這樣的行為建議如何執行來符合公司規範？如何確保工作效率的前提並保持機密維護性？

學到甚麼？

需確認專案相關之實體材料被妥善且具隱密性保管

居家辦公期間避免被非專案相關人員窺視或探詢其內容

Q 2 - 6 外出與居家工作相關風險

重點note

居家工作時，攜帶實體設備和材料（如筆電、圖板、模型、樣品）需符合公司規範，並確保機密維護性。居家辦公期間，應避免非專案相關人員窺視或探詢其內容。

學到甚麼？

- 設計師在居家或外部工作時，應確保所有實體設計材料和設備都得到妥善且隱密的保管。
- 居家辦公環境應避免非專案相關人員(包含家人朋友)窺視或探詢設計內容。

P a r t 3

不 小 心 跨 越 紅 線 的 代 價

智 慧 財 產 權 到 底 歸 誰 ？

Q 3 - 1

我們知道公司擁有我們在職期間的設計產出，但如果想把一些草圖、Mockup 或未採用的提案放進作品集或個人網站，有沒有什麼明確的規範或流程？例如：要先經過誰同意？哪些內容一定不能公開？

學到甚麼？

Q 3 - 1 智慧財產權到底歸誰？

重點note

根據法律規定，員工在職期間的設計產出，其智慧財產權歸公司所有，因為公司已支付報酬。若想將草圖、Mockup 或未採用的提案放入作品集或個人網站，需先取得公司主管書面同意，且某些機敏內容可能絕對不能公開。離職後，雖然公司無法完全管控個人行為，但仍建議諮詢 HR 和法務，以避免法律糾紛。若設計產出之內容已公開宣傳，則無公開疑慮。

學到甚麼？

- 設計師應清楚了解公司智慧財產權歸屬
- 在公開個人作品集前，務必確認內容是否涉及公司機密，並尋求相關部門的同意與指導。

P a r t 3

不 小 心 跨 越 紅 線 的 代 價

設 計 模 型 要 怎 麼 報 廢 才 合 規 ？

Q 3 - 2

我們悉知針對設計圖文紙本物件須由碎紙機碎成百條徹底銷毀
但像是產品開發過程中的**實體模型**完成任務後，應如何進行報廢處理？
怎樣算是實務上「完成實體物件報廢」的定義？
公司有沒有哪些具體指引或規範？

學到甚麼？

Q 3 - 2 設計模型要怎麼報廢才合規？

重點note

對於模型、樣品等非紙類實體產出，目前公司缺乏統一銷毀規範。銷毀的總體原則是「**破壞至無法辨識**」。設計師應有**生命週期管理**的思維，當模型或樣品已無機密性或商業價值時（如產品已上市），就應考慮銷毀。若不確定如何處理，可諮詢總務管理單位。

學到甚麼？

- ADC應自訂**實體設計模型與樣品在完成任務後的報廢流程**，確保其銷毀方式符合公司資安規範，避免機密設計資訊外洩。

***大掃除丟的硬體是沒有機密銷毀的，只有分類回收，ADC須定義被廢SOP**

P a r t 3

不 小 心 跨 越 紅 線 的 代 價

發 生 資 安 事 件 ， 公 司 會 如 何 調 查 ？

Q 3 - 3

資安事件發生後，公司會採取哪些技術手段進行調查？
無形資產損失該如何評估？有沒有一些具體的案例可以跟我們分享？

學到甚麼？

Q 3 - 3 發生資安事件，公司會如何調查？

重點note

資安事件發生後，公司會透過技術手段進行調查，重點在於是否有**足夠的 LOG 記錄**來追溯帳號操作和行為，以便事後舉證。**可識別的足跡**是調查的關鍵。無形資產損失的評估可透過量化依據，但具體案例較難。曾有員工因使用未經授權的跑分軟體，導致 Intel 新 CPU 資訊外洩，最終雖無懲處，但公司需向 Intel 解釋。

學到甚麼？

- 設計師應了解資安事件的嚴重性，並配合公司的調查流程。
- 避免**使用未經授權的軟體或工具**，以免無意間洩漏了機敏資訊。
- 平時處理機敏資訊時應該具有建立足跡的思維，若出了事情可以幫助公司查找。

P a r t 4

給 設 計 師 的 通 則 建 議

設計師在工作中最需要注意的資安思維是什麼？

Q 4 - 1

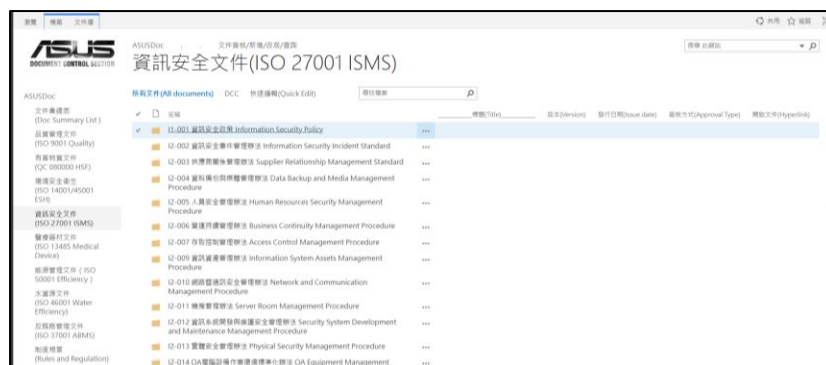
設計過程常涉及初期草圖、產品概念圖、未公開的提案內容，感覺所有都是極機密。對設計師來說，有沒有簡單明確的原則可以幫助我們判斷什麼資訊容易踩雷？又有哪些常見但容易被忽略的資安失誤呢？

學到甚麼？

Q 4 - 1 設計師在工作中最需要注意的資安思維是什麼？

重點note

設計師在工作中應特別注意資料機密性。可參考公司**內部資料對照表**（**對照 EIP 的 ISO 27001** <https://portal.asus.com/sites/Q-Committee/AsusDoc/ISO%2027001%20ISMS/Forms/AllItems.aspx>）。拍照時需判斷是否涉及產品機密，在公區純分享公司生活若不涉密則無妨。ADC辦公區域、管制區內禁止拍照。資安原則應從嚴。



學到甚麼？

- 設計師應培養高度的資安意識，在日常工作中時刻考慮資料的機密性。
- 在拍照或分享資訊前，務必提高自我評估潛在風險意識，並遵循公司最嚴格的資安規範。

P a r t 4

給 設 計 師 的 通 則 建 議

如果我對某個操作有資安疑慮，應該怎麼問、找誰問？

Q 4 - 2

有時候我們會卡在「這樣做好像不太對，但也不確定能不能問」的情境。公司是否提供讓員工安心提問、又不會留下紀錄或被誤會的管道？什麼樣的問題是可以主動提問的？

學到甚麼？

Q 4 - 2 如果對某個操作有資安疑慮，應該怎麼問、找誰問？

重點note

若設計師對某個操作有資安疑慮，可查詢公司內部資訊安全 **infosec** 或撥打 21885 詢問。此外，還可透過 CEO onlive 平台提問，問題會回報給相關單位。也可事先收集問題，或在 CEO 說明會上提出。，公司鼓勵員工安心提問，且不會留下紀錄或被誤會。

學到甚麼？

- 設計師應善用公司提供的資安諮詢管道，主動提出資安疑慮，確保操作合規。
- 不必擔心因提問而受到懲罰或留下不良記錄。

P a r t 4

給 設 計 師 的 通 則 建 議

設 計 師 可 以 怎 麼 幫 助 團 隊 一 起 維 護 資 安 ？

Q 4 - 3

如果不是資安或IT人員，設計師能不能也在日常工作中成為推動資安文化的一份子？
有沒有幾個我們可以落實的小行動或提醒，能讓整個團隊更安全？

學到甚麼？

Q 4 - 2 如果對某個操作有資安疑慮，應該怎麼問、找誰問？

重點note

設計師即使不是資安或 IT 人員，也能在日常工作中成為推動資安文化的一份子。可透過落實「**資訊安全十守則**」（小卡，可在 EIP 系統的「數位安全資訊」中找到）來幫助團隊維護資安。這些守則提供了明確的行為規範。公司鼓勵員工從自身做起，維護資安。若有違規，資安部門會提報給部門最高主管，並依循公司流程和委員會審核，確保程序透明且有證據支持。

學到甚麼？

- 應積極參與並推動團隊的資安文化，從自身做起，嚴格遵守公司資訊安全十守則。
- 主動透過日常的小行動和提醒，共同提升團隊的資安防護能力。